CYS 335: ACCESS CONTROL AND INTRUSION DETECTION



Lesson 1

I. The State Of Threats Against Computer And Networked System

A. Modern Threat Environment
B. Attack Surface Expansion: New Frontiers Of Vulnerability

A. Modern Threat Environment

- Modern computer systems are constantly exposed to threats due to:
  - Increased internet connectivity
  - Cloud computing
  - Mobile devices and remote access
  - Internet of Things (IoT)



A. Modern Threat Environment...

- Attackers no longer need physical access. A single vulnerable service exposed online can be exploited from anywhere in the world.
- Security threats evolve faster than traditional security controls.



The Evolution of Cyber Threats

- **1980s–1990s: The Era of Experimentation**
  - **Characteristics:** Simple viruses and worms, often created for curiosity or fame
  - **Examples:** Morris Worm (1988), Michelangelo virus
  - **Key Limitation:** Limited network connectivity contained spread
  - **Motivation:** Mostly non-malicious, experimental

Evolution of Cyber Threats...

- **2000s: The Rise of Financial Motivation**
  - **Characteristics:** Mass malware outbreaks, email-based attacks becoming mainstream
  - **Examples:** ILOVEYOU worm, Code Red, SQL Slammer
  - **Motivation:** Financial gain through spam, adware, and early ransomware



Evolution of Cyber Threats

- **2010s–Present: The Age of Sophistication**
  - **Characteristics:** Advanced, persistent, and often state-sponsored attacks
  - **Examples:** Stuxnet, WannaCry, SolarWinds supply chain attack



Why the Traditional "Castle-and-Moat" Security Model Fails

- Because it assumes threats only come from outside, protecting the perimeter while leaving the internal network vulnerable to lateral movement, insider threats, and compromised credentials.



Real-World Examples of Perimeter Failure

- **Example 1:**
  - A firewall allows all HTTPS traffic (port 443).
  - Malware establishes an encrypted channel to its command server through this allowed port.



Real-World Examples of Perimeter Failure...

- **Example 2:**
  - An employee's VPN credentials are stolen via phishing. The attacker now has legitimate full network access.

Real-World Examples of Perimeter Failure...

- **Example 3:** A cloud storage bucket is misconfigured to be publicly accessible, bypassing all network perimeter controls.



Real-World Examples of Perimeter Failure…

- Perimeter security alone cannot detect malicious behavior occurring inside the network.
- Once an attacker breaches the perimeter, traditional defenses often become blind to their activities.



B. Attack Surface Expansion: New Frontiers Of Vulnerability

- **Attack Surface:**
  - Is the sum of all points where an unauthorized user can try to enter or extract data from your environment.



1. Cloud Vulnerabilities

- **Misconfigured Storage:** Publicly accessible S3 buckets, blob storage
- **Insecure APIs:** Cloud service APIs with weak authentication
- **Identity and Access Management (IAM) Issues:** Overly permissive roles
- **Secret Management:** Hard-coded credentials in cloud scripts



2. Mobile Devices - The Borderless Endpoint

- **BYOD (Bring Your Own Device):** Personal devices accessing corporate data
- **App-Based Threats:** Malicious apps, data leakage through permissions
- **Physical Security Risks:** Lost or stolen devices with corporate access
- **Unsecured Networks:** Devices connecting through public WiFi



3. Internet of Things (IoT) - The Security Afterthought

- **Weak Authentication:** Default passwords, no multi-factor authentication
- **Unpatched Firmware:** Manufacturers rarely provide security updates
- **Lack of Encryption:** Data transmitted in clear text
- **Minimal Processing Power:** Cannot support robust security controls



4. Operational Technology (OT)

- Industrial control systems (ICS) now connected to IT networks
- Legacy systems never designed for internet connectivity
- Critical infrastructure with outdated, unpatchable software
- Each new technology adoption increases vulnerability points, creating a complex web of interconnected risks.

5. Interconnected Systems

- The Domino Effect in Modern Networks:
  - ✓Modern systems are highly interdependent. A compromise in one system can cascade through connected systems like falling dominoes.

5. Interconnected Systems...

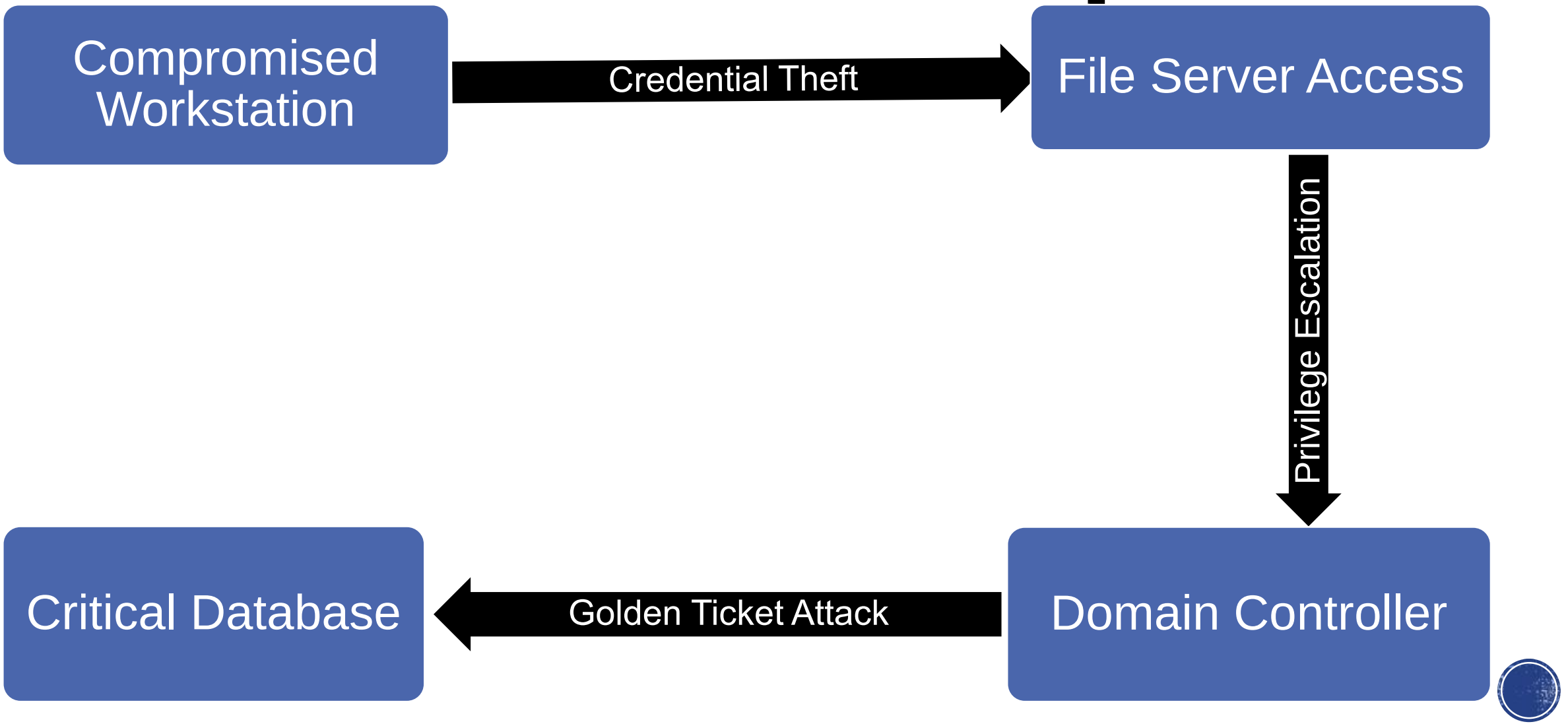
- The "domino effect" in modern networks refers to a cascading failure where a single, often minor, disruption in a hyper-connected digital ecosystem triggers secondary and tertiary failures across APIs, SaaS, CDNs, and critical infrastructure.

Common Attack Paths in Interconnected Systems

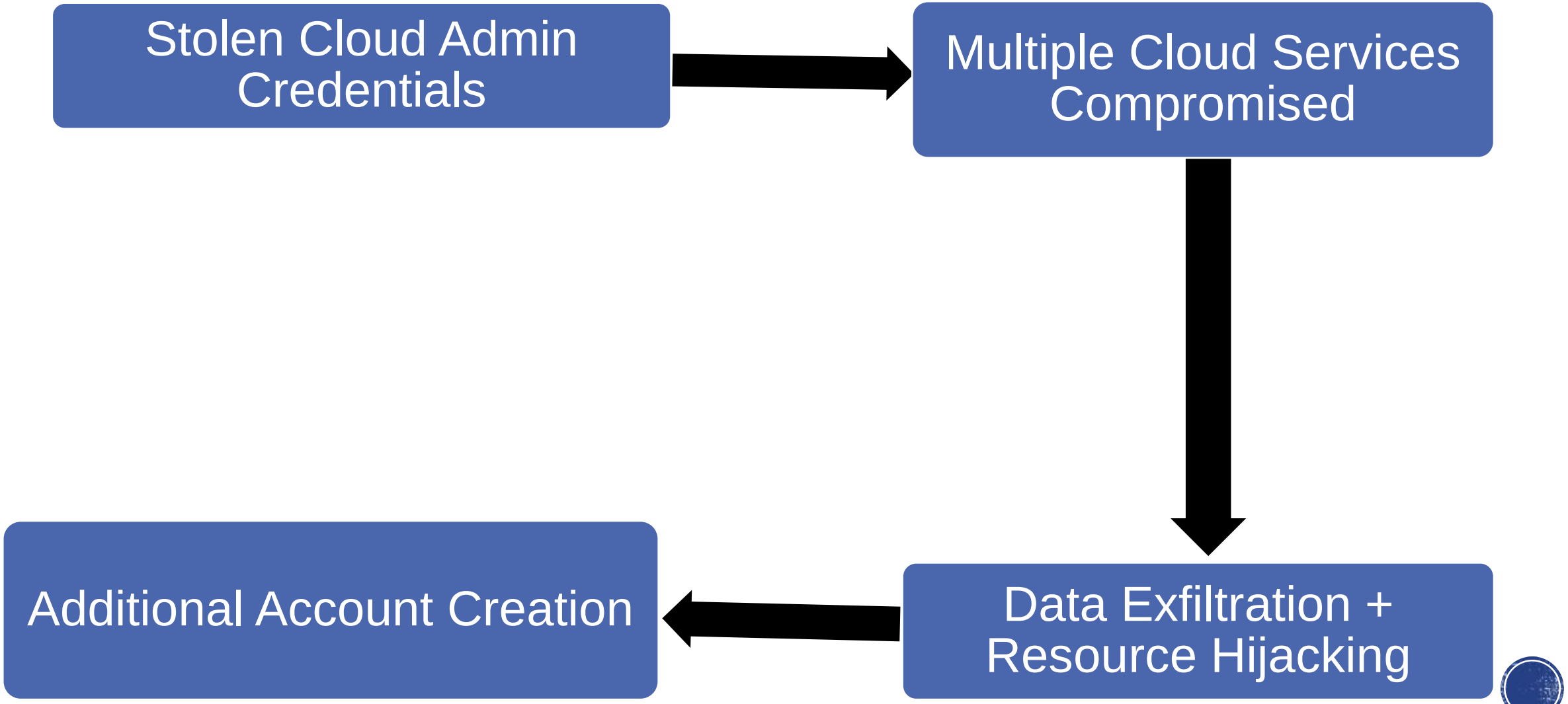
- Lateral Movement Sequence
- Cloud Identity Compromise
- Supply Chain Attack Propagation



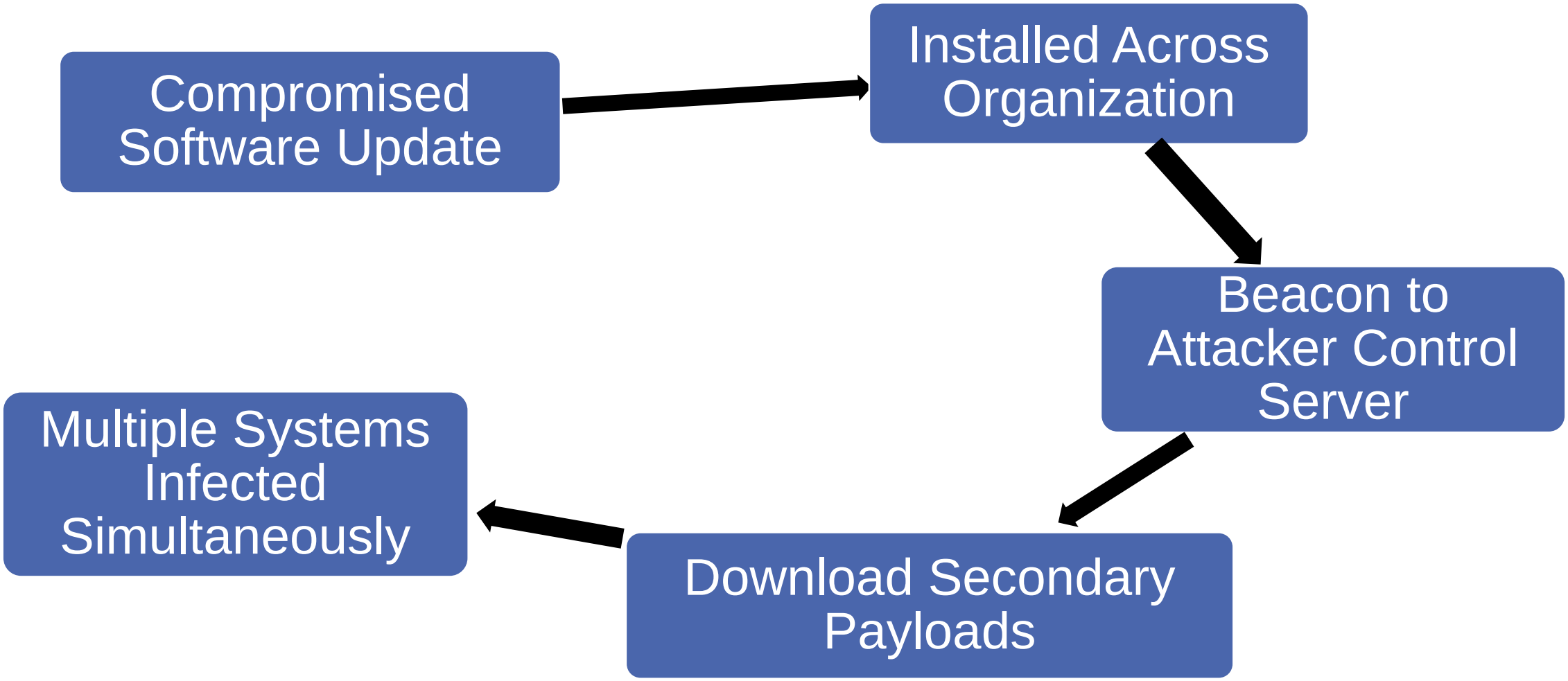
Lateral Movement Sequence



Cloud Identity Compromise



Supply Chain Attack Propagation



Risk Amplifiers in Interconnected Environments

1. **Single Sign-On (SSO) Risks:**
   - Compromise one account → Access to multiple systems
   - Lack of application-level authorization checks



Risk Amplifiers in Interconnected Environments…

2. **Poor Network Segmentation:**
   - Flat networks allow easy lateral movement
   - Critical systems accessible from user workstations



Key Risk Amplifiers in Interconnected Environments…

3. **Excessive Privileges:**
   - Users with unnecessary administrative rights
   - Service accounts with domain-wide privileges



Key Risk Amplifiers in Interconnected Environments…

4. **Implicit Trust Relationships:**
   - Systems trusting all others in same subnet
   - Automated trust between cloud services



II. Computer Security Solutions

A. Vulnerability Assessment Tools
B. Firewalls
C. Virtual Private Networks (VPNs)

The Three Critical Aspects of Security

1. **Prevention:** Stop attacks before they succeed (firewalls, access controls)
2. **Detection:** Identify attacks that bypass prevention (IDS, monitoring)
3. **Response:** Contain and eradicate successful attacks (incident response)



A. Vulnerability Assessment Tools

- Scan systems for known weaknesses
- Compare system configurations against vulnerability databases



Examples of Vulnerability Assessment Tools

- Nessus
- OpenVAS
- Qualys



Advantages of Vulnerability Assessment Tools

- Identify known vulnerabilities
- Support compliance requirements



Limitation of Vulnerability Assessment Tools

- Cannot detect unknown (zero-day) vulnerabilities
- Do not identify active attacks
- Often generate false positives



B. Firewalls

- Firewalls control network traffic based on predefined rules.



1. Packet Filtering Firewalls

- Inspect packets individually
- Use source/destination IP and port numbers



Advantages of Packet Filtering Firewalls

- Simple
- Fast



Limitation of Packet Filtering Firewalls

- No session awareness
- Cannot detect application-layer attacks



2. Stateful Inspection Firewalls

- Track the state of network connections
- Allow traffic based on session legitimacy



Advantages of Stateful Inspection Firewalls

- More secure than packet filtering
- Prevent spoofed packets



Limitation of Stateful Inspection Firewalls

- Limited visibility into application data



3. Next-Generation Firewalls (NGFW)

- Application awareness
- Deep Packet Inspection (DPI)
- Integrated IDS/IPS features



Advantages of Next-Generation Firewalls (NGFW)

- Better visibility
- Improved control



Limitation of Next-Generation Firewalls (NGFW)

- High cost
- Performance overhead
- Still reactive to known threats



C. Virtual Private Networks (VPNs)

- VPNs provide encrypted communication over untrusted networks.



Virtual Private Network (VPNs) Types

1. **Site-to-Site VPN**
   - Connects two networks securely
   - Common in branch office connectivity



Virtual Private Networks (VPNs) Types…

2. **Remote Access VPN**
   - Allows individual users to access internal networks remotely



Strengths of Virtual Private Networks (VPNs)

- Protect data in transit
- Enable secure remote work
- Prevent eavesdropping



Weaknesses of Virtual Private Networks (VPNs)

- Do not verify user intent
- Malware can operate inside VPN tunnels
- Stolen credentials grant full access



Why These Computer Security Solutions Alone Are Insufficient

- Focus on access control
- Assume trusted users behave correctly
- Fail to detect insider abuse or compromised accounts
- They do not monitor behavior after access is granted.

